Family Care: תיאור מערכת ומאגר מידע

מסמך רקע לעורך דין / יועץ פרטיות, לצורך חוות דעת בנושא הגנת הפרטיות (כולל תיקון 13 לחוק הגנת הפרטיות ותקנות אבטחת מידע). עודכן נובמבר 2026. המסמך מתאר את המצב הנוכחי, ואינו מהווה חוות דעת משפטית.

1. מי אנחנו ומה השירות

Family Care: מועדון קונסיירז' לבני 65+ ולמשפחותיהם בישראל. השירות כולל מלווים אישיים, תיאום רפואי ומשפטי-בירוקרטי, אחזקת בית ופנאי. הפעילות מנוהלת במערכת ווב פנימית (CRM) ובאתר ציבורי. [לעדכן: שם הישות המשפטית, מספר חברה, בעלי העסק ואיש קשר לענייני פרטיות.]

2. סוגי המידע שנאספים

מי	סוג מידע	רגישות
לקוח/ה (65+)	שם, תאריך לידה, מגדר, כתובת, טלפון, קוד כניסה לבניין, מצב ניידות, מצב קוגניטיבי, תרופות, אלרגיות, העדפות אישיות, סיכומי ביקורים, שאלון היכרות (כולל נתוני בריאות, מצב משפחתי, מצב כלכלי, פרטי גישה לבית), מסמכים משפטיים שהועלו (ייפוי כוח וכד')	מידע רגיש (בריאות) ונתוני פגיעות
בני משפחה / מזמינים	שם, טלפון, דוא"ל, קרבה, הרשאות גישה, הודעות במערכת	רגילה
לקוחות פוטנציאליים (לידים)	שם, טלפון, דוא"ל (רשות), הערות, מקור הפנייה (כולל מטופס באתר)	רגילה
מלווים ועובדים	שם, טלפון, שפות, אזורי פעילות, תמונה, שכר ושעות, וכן תיק אישי: סיכום פגישות, טופס ראיון, חוזה עבודה חתום	רגילה עד רגישה (חוזה, הערכות)
ספקים ובעלי מקצוע	פרטי קשר, תעריפים, תוקף ביטוח/רישוי	רגילה
גולשים באתר	Google Analytics רק אחרי הסכמה (אירועי שימוש מצטברים); נתוני התחברות באזור האישי	רגילה

3. מטרות ושימוש

מתן השירות ותיאומו, תפעול ושיבוץ מלווים, חיוב וגבייה, תקשורת עם משפחות, בקרת איכות וטיפול בתלונות, גיוס מלווים, וחזרה לפונים באתר. אין מכירה או העברה של מידע לצדדים שלישיים לצורכי שיווק (כך מופיע בתקנון, סעיף 7.3).

4. תשתית טכנית וספקי עיבוד

ספק	תפקיד	מיקום / הערות

Supabase	בסיס הנתונים, התחברות משתמשים, אחסון קבצים	[לוודא אזור שרתים בלוח הבקרה; לא ידוע כרגע]. תוכנית נוכחית: [לבדוק: חינמית/Pro]. הסכם עיבוד מידע (DPA): [לבדוק]
Cloudflare	ניהול דומיין ו-DNS, ניתוב דוא"ל נכנס; בהמשך אירוח האתר	DPA: [לבדוק]
Resend	שליחת דוא"ל התראה למשרד על פנייה חדשה מהאתר (שם, טלפון, דוא"ל והערות של הפונה)	אזור הדומיין: eu-west-1 (אירלנד); חברה אמריקאית. DPA: [לבדוק]
GitHub	אחסון קוד ואירוח האתר הציבורי (אין בו מידע אישי של לקוחות)	המאגר ציבורי כיום; בתכנון הפיכה לפרטי
Google (Analytics, Gmail)	מדידת שימוש באתר (בהסכמה); תיבות דוא"ל של בעלי העסק	—

5. אמצעי אבטחה קיימים

- בסיס הנתונים: Row Level Security בכל הטבלאות, גישה אנונימית חסומה לחלוטין. טופס הפרטים באתר פועל דרך פונקציה ייעודית עם הגבלת קצב (20 פניות בשעה), בדיקת קלט וזיהוי רובוטים.
- הרשאות לפי תפקיד: מנהל, משרד (לפי מחלקות), מלווה (רק לקוחות המשובצים אליו), משפחה (רק ההורה שלה). מידע רגיש ביותר (קודי גישה, סיסמאות, חיוב) בטבלאות נפרדות לגישת מנהלים בלבד.
- מסמכים רגישים (ייפוי כוח, חוזים) בתיקיות אחסון פרטיות, נפתחים בקישור זמני בן שתי דקות.
- התחברות אישית; אימות דו-שלבי (TOTP) זמין למנהלים ולצוות המשרד (רשות, לא חובה כרגע).
- יומן גישה לתיק לקוח (מי פתח או ייצא ומתי), למנהלים בלבד. [מתחיל לפעול עם הרצת העדכון האחרון]
- טיוטות של שאלון הלקוח לא שומרות מידע רגיש בדפדפן.
- ייצוא מידע ללקוח לפי בקשת עיון, והודעה והסכמה לאיסוף מידע בשאלון הקליטה.

6. פערים ידועים (לדעתנו, לפני חוות הדעת)

- אין עדיין נוהל כתוב לבקשות עיון, תיקון ומחיקה, ולמחיקת לקוחות יש חסימה טכנית כשיש ביקורים וחשבוניות (שמירה לצורכי חשבונאות).
- לא הוגדרה מדיניות שמירת מידע (כמה זמן שומרים לקוח שעזב, לידים, תיקי מלווים שפרשו).
- לא נעשתה הערכת רמת אבטחה לפי תקנות הגנת הפרטיות (אבטחת מידע), ולא הוגדר ממונה הגנת פרטיות או נוהל אירוע אבטחה.
- האימות הדו-שלבי אינו חובה, ואין אכיפה ברמת בסיס הנתונים.
- הסכמי עיבוד מידע עם הספקים לא נבדקו/נחתמו, ומיקום השרתים לא אומת.
- הסכמה לדיוור שיווקי (WhatsApp / דוא"ל) לפי חוק התקשורת (סעיף 30א) טרם מנוסחת.
- לא נעשה מבחן חדירות או סקירת אבטחה חיצונית.

7. שאלות לעורך הדין

1. האם חלה חובת רישום מאגר או מינוי ממונה הגנת פרטיות (בהינתן מידע רפואי של בני 65+ והיקף הפעילות הצפוי)? באיזו רמת אבטחה לפי התקנות?
2. האם נוסח ההודעה וההסכמה בשאלון הקליטה ובמדיניות הפרטיות (סעיף 7 בתקנון) מספיק, ומה צריך להוסיף, בפרט כשמי שמזמין הוא בן משפחה ולא הלקוח עצמו?
3. העברת מידע לשרתים מחוץ לישראל (אירופה, ארה"ב): מה נדרש (הודעה, הסכמה, הסכמי עיבוד)?
4. משך שמירת מידע: לקוחות שעזבו, לידים שלא התקדמו, מסמכי מלווים, וחשבוניות. איך משלבים בין זכות מחיקה לחובות חשבונאיות?
5. הסכמה ללקוחות פגיעים או עם מגבלות קוגניטיביות: מי רשאי להסכים בשמם (ייפוי כוח, בן משפחה)?
6. נוהל בקשות עיון/תיקון/מחיקה ונוהל דיווח על אירוע אבטחה: נשמח לתבנית.
7. עיבוד מידע עובדים (תיק אישי, חוזה, סיכום פגישות): הודעה ויסודות חוקיים.
8. נוסח הסכמה לדיוור שיווקי בהתאם לסעיף 30א לחוק התקשורת.

מצורפים לפי בקשה: צילומי מסך של המערכת, תקנון החברה (מופיע גם ב-myfamilycareclub.com/policy), שאלון הקליטה, ורשימת טבלאות ושדות.